

Curso de Especialización Ciberseguridad en las TIC

EJ-2. SEGURIDAD PARA SERVICIOS WEB OWASP

Objetivos

- Analizar la seguridad en producción de APIs y servicios web aplicando las recomendaciones de OWASP para identificar riesgos y definir controles de mitigación.

Resumen

Autora: Marina del Pilar López Oliva

Diciembre-2025

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Índice de Contenidos

1. Ejercicio 2.....	4
1.1 Diseño seguro de endpoints.....	4
1.2 Configuración de gateways / proxies inversos.....	4
1.3 Monitoreo del consumo y abuso de APIs.....	5

1. Ejercicio 2.

1.1 Diseño seguro de endpoints

Un diseño seguro de endpoints debe mitigar riesgos antes incluso de escribir código. Para evitar patrones de vulnerabilidad recogidos en OWASP Top 10 y OWASP API Security.

- Validación estricta de entrada: definir y validar el formato y contenido esperado mediante herramientas como JSON Schema, validadores de framework, etc. Se rechaza cualquier dato que no cumpla el esquema para prevenir inyecciones, deserialización insegura, etc.
- Autorización explícita: nunca se debe asumir que el cliente tiene permisos. Se aplica autorización a nivel de recursos y de propiedad para evitar que campos sensibles puedan ser modificados.
- Mecanismos anti-abuso: diseñar operaciones sensibles que incluyan limitadores.
- Principio de minimización de datos: asegurar que los endpoints de respuesta solo devuelvan la información indispensable para el cliente.
- Modelado de amenazas: antes de implementar, deben analizarse posibles escenarios de abusos para identificar. Esto permite corregir errores antes de llegar al código.

1.2 Configuración de gateways / proxies inversos

Los gateways y proxies actúan como capa de seguridad previa al backend y permiten aplicar políticas globales antes de procesar la petición.

- HTTPS obligatorio y hardening de TLS.
- WAF / API Firewall.
- Configuración restrictiva de CORS.
- Inclusión de cabeceras de seguridad HTTP.
- Inventario y cierre de versiones obsoletas.
- Validación centralizada de tokens en el gateway.
- Protección contra SSRF desde el gateway.

1.3 Monitoreo del consumo y abuso de APIs

El monitoreo es esencial para detectar ataques en curso que hayan evadido las capas de seguridad anteriores.

- Rate limiting multi-capa: aplicar límites de consumo no solo a nivel de IP, sino también a nivel de usuario y a endpoints críticos.
- Logging de eventos sospechosos: implementar un sistema de logging centralizado en fallos de autenticación, errores de autorización y patrones de abuso.
- Alertas de comportamientos anómalos: configurar alertas en tiempo real.
- DAST periódico: realizar escaneos dinámicos automáticos y pruebas de seguridad periódicas.
- Dashboards de métricas: supervisar continuamente la disponibilidad, la tasa de errores, la latencia, etc. Lo que facilita identificar degradación o abusos.